

CONTRACT RISK ASSESSMENT GUIDELINES

Standard Operating Procedure & Legal Risk Evaluation Framework

Document Reference: SOP-LEG-004

Effective Date: Q3 2026

Target Audience: Legal Counsel & Contracts Team

Purpose: This document establishes a systematic protocol for evaluating, scoring, and mitigating risks within commercial agreements prior to execution. Counsel must conduct reviews against the thresholds set below and ensure appropriate escalations occur when red-flag provisions are identified.

1. RISK ASSESSMENT METHODOLOGY

Contractual risk is calculated by evaluating the **Severity of Impact** against the **Probability of Occurrence**. Counsel must categorize total contractual risk into one of four tiers, dictating the required approval authority.

Probability	Impact Severity			
	Minor (1)	Moderate (2)	Major (3)	Critical (4)
High (4)	Medium (4)	High (8)	Critical (12)	Critical (16)
Medium (3)	Low (3)	Medium (6)	High (9)	Critical (12)
Low (2)	Low (2)	Low (4)	Medium (6)	High (8)
Unlikely (1)	Low (1)	Low (2)	Low (3)	Medium (4)

Governance & Approval Escalation Thresholds

- **Low Risk (1–3):** Standard Legal Counsel sign-off.
- **Medium Risk (4–6):** Senior Legal Counsel or Lead Commercial Counsel sign-off required.
- **High Risk (8–9):** General Counsel + Business Unit Head approval required.
- **Critical Risk (12–16):** Executive Officer / CFO approval required; formal Board notice if liability is uncapped.

2. CLAUSE-BY-CLAUSE REVIEW CHECKLIST

A. Liability & Indemnification (High Priority)

Clause Category	Red Flags (High Risk)	Standard / Preferred Position	Risk Level
Limitation of Liability (LoL)	• Silence on liability caps (uncapped exposure). • Cap tied to unrealistic multipliers or total contract value without annual sub-caps. • Unilateral carve-outs benefiting only the counterparty.	• Mutual liability cap equal to 1x–2x fees paid in preceding 12 months. • Clear exclusion of indirect/consequential damages.	CRITICAL
Indemnification	• Broad, uncapped indemnities for breach of contract or negligence. • Obligation to defend/indemnify third-party claims without sole control of defense.	• Indemnities capped at LoL, limited to IP infringement, gross negligence, willful misconduct, and data breach.	CRITICAL
Consequential Damages	• No waiver of indirect, special, punitive, or loss-of-profit damages.	• Express mutual waiver of consequential damages.	HIGH

B. Operational & Financial Provisions

Clause Category	Red Flags (High Risk)	Standard / Preferred Position	Risk Level
Payment & Pricing	• Payment terms > 60 days. • Unilateral price increase clauses without advance notice or termination rights. • Strict audit/penalty fees for late payment.	• Net 30 or 45 days. • Annual price increases capped at CPI or max 3–5%, with 60 days prior written notice.	MEDIUM
Scope & Deliverables	• Vague acceptance criteria ("to satisfaction"). • Deemed acceptance without formal review windows. • Uncontrolled scope changes.	• Objective acceptance criteria with explicit review timelines (e.g., 10 business days) and formal Change Order protocol.	HIGH
SLA & Penalties	• Unlimited liquidated damages. • Direct termination rights for minor SLA breaches without cure period.	• SLA credits as sole and exclusive remedy; total credits capped at 15–20% of monthly fee.	MEDIUM

C. Termination & IP Protection

Clause Category	Red Flags (High Risk)	Standard / Preferred Position	Risk Level
Termination Rights	• Auto-renewal with short notice window (< 30 days). • Termination for convenience by counterparty without compensation/unwinding fees. • No cure period for curable breaches.	• Mutual right to terminate for uncured material breach (30 days written notice). • 60–90 days notice for non-renewal.	HIGH
Intellectual Property	• Assignment of pre-existing background IP. • Work-for-hire provisions transferring proprietary tools/methods to client.	• Retention of pre-existing IP. • Customer receives license to deliverables; provider retains underlying tools/platform IP.	CRITICAL
Data Privacy & Security	• Absence of Data Processing Addendum (DPA) where personal data is processed. • Uncapped liability for data security incidents.	• Standard DPA attached incorporating SCCs/GDPR compliance. • Data breach notification within 48–72 hours. • Data breach liability super-cap (e.g., 2x–3x fee cap).	HIGH
Governing Law & Jurisdiction	• Unfavorable foreign jurisdiction or governing law. • High-cost dispute resolution mechanisms without initial negotiation escalation.	• Local governing law/jurisdiction, or neutral venue (e.g., Delaware, New York, London). Multi-tiered dispute resolution.	MEDIUM

3. STEP-BY-STEP LEGAL RISK ASSESSMENT WORKFLOW

Step 1: Preliminary Scoping & Intake Assessment

Identify contract type, total contract value (TCV), strategic importance, and counterparty leverage. Confirm all exhibits, schedules, and referenced online terms are present.

Step 2: Automated & Manual Redline Review

Cross-reference draft terms against the Clause-by-Clause Checklist above. Highlight non-standard provisions and assign an initial risk rating (Low, Medium, High, Critical).

Step 3: Stakeholder Alignment & Commercial Consultation

Engage internal business owners (Finance, IT, Ops, Information Security) to validate operational risks, SLA feasibility, data flows, and margin implications.

Step 4: Risk Mitigation & Fallback Drafting

Apply institutional fallback language for all identified red flags. If counterparty refuses standard fallbacks, prepare formal Legal Risk Memorandum detailing remaining risks.

Step 5: Governance Approval & Execution

Secure formal sign-off based on the Risk Matrix Thresholds in Section 1 before routing the document for final signature via approved e-signature platforms.